

DDoS Attacks

Distributed Denial of Service Attacks

Prof. (Dr.) Anand Nayyar

School of Computer Science and AI
Duy Tan University, Viet Nam



DDoS Attacks

- DoS Basics
- DDos Attack Description
- DDos Attack Taxonomy
- Well known DDoS attacks
- Defense Mechanisms
- Modern Techniques in Defending
- Questions!



DoS Basics

- What is Internet?
- What resources you access through Internet?
- Who uses those resources?
- Good vs Bad Users
- Denial-of-Service attack
 - a.k.a. DoS attack is a malicious attempt by a single person or a group of people to cause the victim, site, or node to deny service to its customers.
- DoS vs DDoS
 - DoS: when a single host attacks
 - DDos: when multiple hosts attacks simultaneously



DDos Attack Description

- exhaust the victim's resources
 - network bandwidth, computing power, or operating system data structures
- DDos Attack
 - build a network of computers
 - discover vulnerable sites or hosts on the network
 - exploit to gain access to these hosts
 - install new programs (known as *attack tools*) on the compromised hosts
 - hosts that are running these attack tools are known as *zombies*
 - many zombies together form what we call an *army*
 - building an *army* is automated and not a difficult process nowadays



DDos Attack Description

- How to find Vulnerable Machines?
 - *Random scanning:*
 - infected machines probes IP addresses randomly and finds vulnerable machines and tries to infect it
 - creates large amount of traffic
 - spreads very quickly but slows down as time passes
 - E.g. Code-Red (CRv2) Worm
 - *Hit-list scanning:*
 - attacker first collects a list of large number of potentially vulnerable machines before start scanning
 - once found a machine attacker infects it and splits the list giving half of the list to the compromised machine
 - same procedure is carried for each infected machine.
 - all machines in the list are compromised in a short interval of time without generating significant scanning traffic
 - *Topological scanning:*
 - uses information contained on the victim machine in order to find new targets
 - looks for URLs in the disk of a machine that it wants to infect
 - extremely accurate with performance matching the Hit-list scanning technique



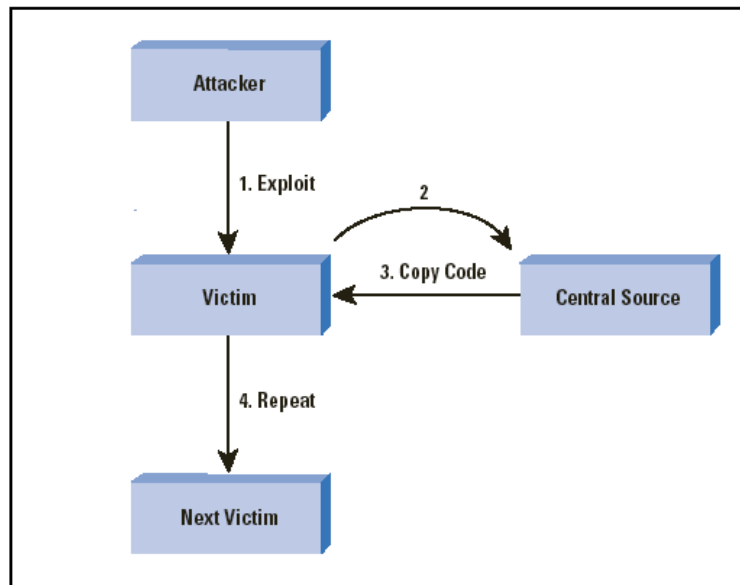
DDos Attack Description

- How to find Vulnerable Machines?
 - *Local subnet scanning*:
 - acts behind a firewall
 - looks for targets in its own local network
 - can be used in conjunction with other scanning mechanisms
 - creates large amount of traffic
 - *Permutation scanning*:
 - all machines share a common pseudorandom permutation list of IP addresses
 - based on certain criteria it starts scanning at some random point or sequentially
 - coordinated scanning with extremely good performance
 - randomization mechanism allows high scanning speeds
 - can be used with hit-list scanning to further improve the performance (partitioned permutation scanning)



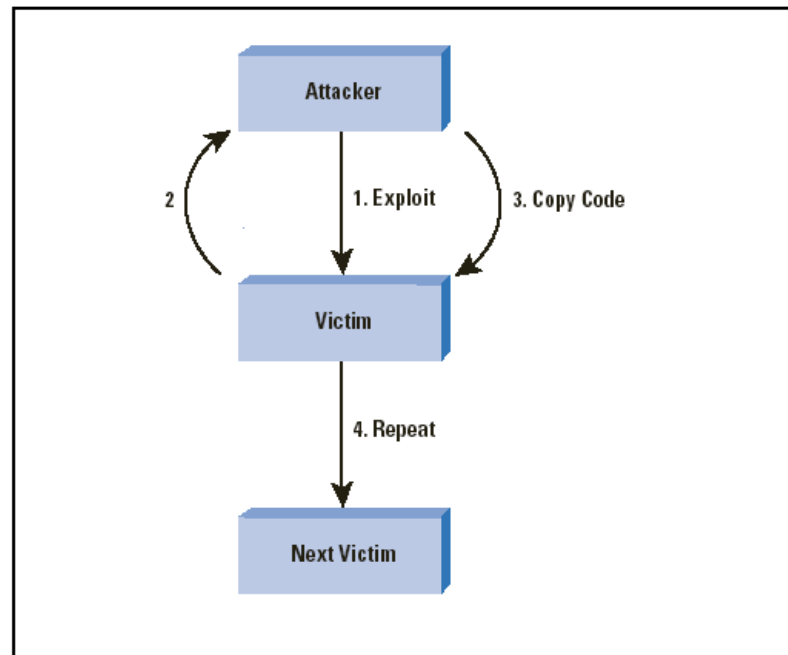
DDos Attack Description

- How to propagate Malicious Code?
 - *Central source propagation:*
 - this mechanism commonly uses HTTP, FTP, and *remote-procedure call* (RPC) protocols



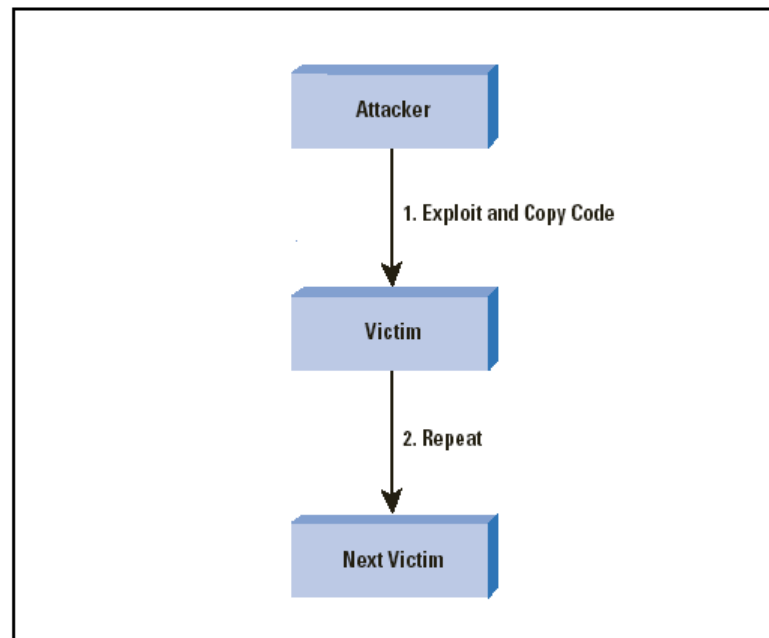
DDos Attack Description

- How to propagate Malicious Code?
 - *Back-chaining propagation*:
 - copying attack toolkit can be supported by simple port listeners or by full intruder-installed Web servers, both of which use the *Trivial File Transfer Protocol* (TFTP)



DDos Attack Description

- How to propagate Malicious Code?
 - *Autonomous propagation:*
 - transfers the attack toolkit to the newly compromised system at the exact moment that it breaks into that system



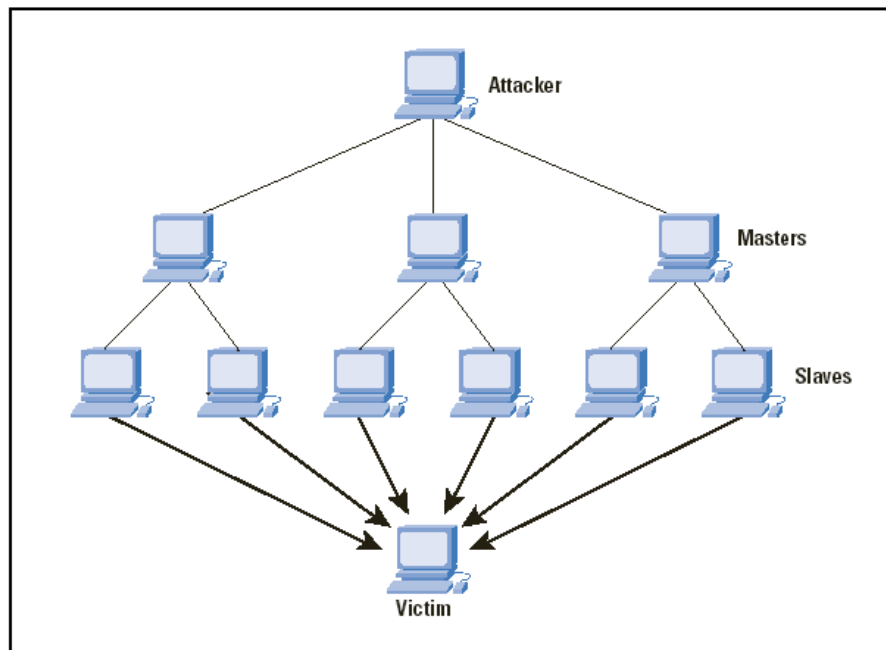
DDoS Attack Description

- How to perform DDoS?
 - after constructing the attack network, intruders use handler (master) machines to specify type of attack and victim's address
 - they wait for appropriate time to start the attack
 - either by remotely activating the attack to “wake up” simultaneously
 - or by programming ahead of time
 - the agent machines (slaves) then begin sending a stream of attack packets to the victim
 - the victim's system is flooded with useless load and exhaust its resources
 - the legitimate users are denied services due to lack of resources
 - the DDoS attack is mostly automated using specifically crafted attacking tools
 - Fapi, Trinoo, *Tribe Flood Network*(TFN & TFN2K), Mstream, Omega, Trinity, Derivatives, myServer, and Plague etc.



DDoS Attack Taxonomy

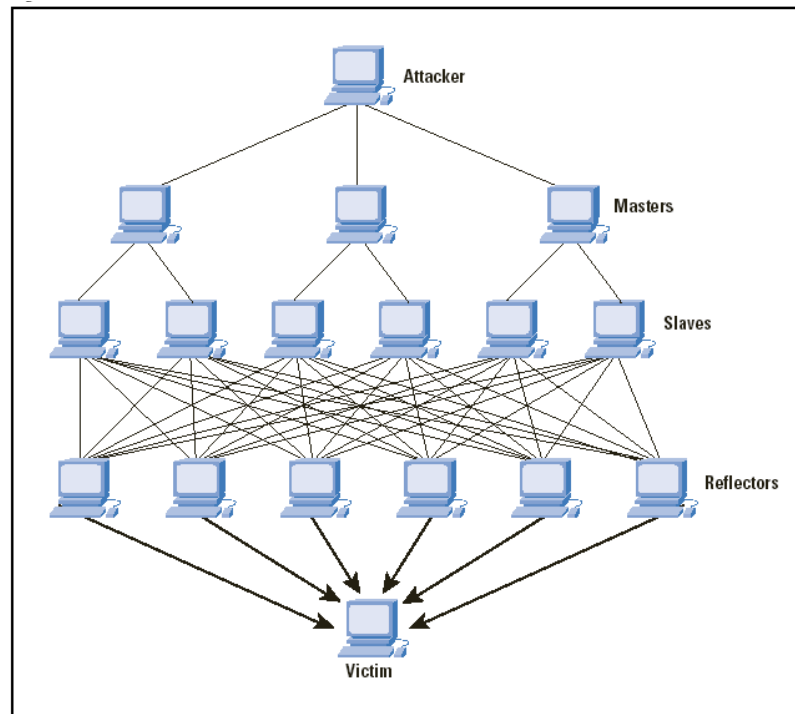
- There are mainly two kinds of DDoS attacks
 - Typical DDoS attacks, and
 - Distributed Reflector DoS (DRDoS) attacks
- *Typical DDoS Attacks:*



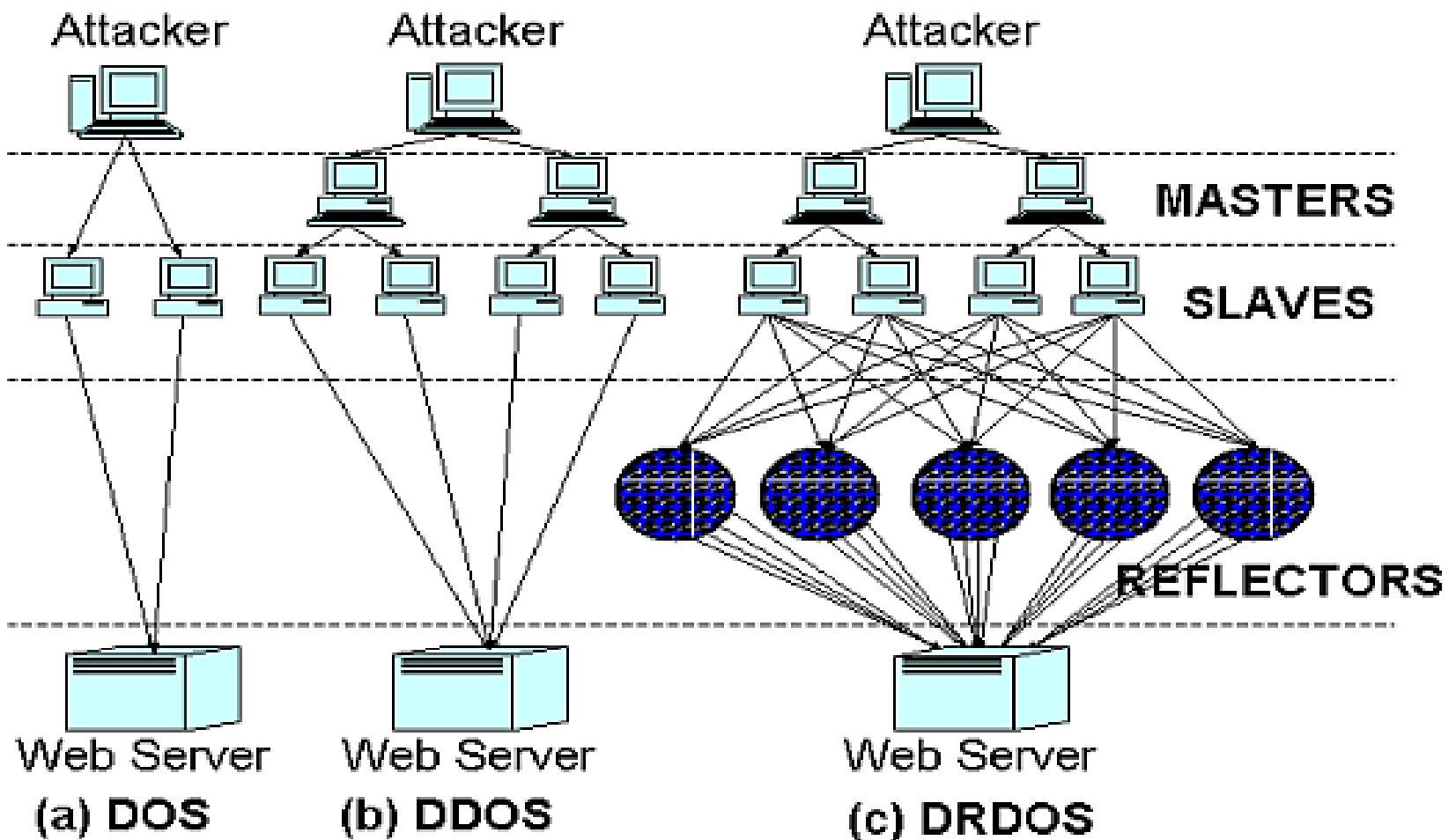
DDoS Attack Taxonomy

– DRDoS Attacks:

- slave zombies send a stream of packets with the victim's IP address as the source IP address to other uninfected machines (known as *reflectors*)
- the reflectors then connects to the victim and sends greater volume of traffic, because they believe that the victim was the host that asked for it
- the attack is mounted by noncompromised machines without being aware of the action



DDoS Attack Description



DDoS Attack Description

A Corporate Structure Analogy

	DOS Model	Corporate Structure
Positions	Attacker Slave Master Reflector	CEO Employee Manager Contractor
Goals	Damages	Profits
Needs	Computational Power	Resources



Well-Known DDoS Attacks

- Some of the most famous documented DDoS attacks
 - *Apache2*:
 - The client asks for a service by sending a request with many HTTP headers resulting Apache Web server to crash
 - *ARP Poison*:
 - *Address Resolution Protocol* (ARP) Poison attacks require the attacker to have access to the victim's LAN
 - The attacker deludes the hosts of a specific LAN by providing them with wrong MAC addresses for hosts with already-known IP addresses
 - The network is monitored for "arp who-has" requests
 - As soon as such a request is received, the malevolent attacker tries to respond as quickly as possible
 - *Back*:
 - This attack is launched against an apache Web server, which is flooded with requests containing a large number of front-slash (/) characters in the URL
 - The server tries to process all these requests, it becomes unable to process other legitimate requests and hence it denies service to its customers.
 - *CrashIIS*:
 - Attacks a Microsoft Windows NT IIS Web server.
 - The attacker sends the victim a malformed GET request, which can crash the Web server.



Well-Known DDoS Attacks

- Some of the most famous documented DDoS attacks
 - *DoSNuke*:
 - In this kind of attack, the Microsoft Windows NT victim is inundated with "out-of-band" data (MSG_OOB). The packets being sent by the attacking machines are flagged "urg" because of the MSG_OOB flag.
 - As a result, the target is weighed down, and the victim's machine could display a "blue screen of death."
 - *Land*:
 - In Land attacks, the attacker sends the victim a TCP SYN packet that contains the same IP address as the source and destination addresses.
 - Such a packet completely locks the victim's system.
 - *Mailbomb*:
 - In a Mailbomb attack, the victim's mail queue is flooded by an abundance of messages, causing system failure.
 - *SYN Flood*:
 - The attacker sends an abundance of TCP SYN packets to the victim, obliging it both to open a lot of TCP connections and to respond to them.
 - Then the attacker does not execute the third step of the three-way handshake that follows, rendering the victim unable to accept any new incoming connections, because its queue is full of half-open TCP connections.



Well-Known DDoS Attacks

- Some of the most famous documented DDoS attacks
 - *Ping of Death*:
 - Attacker creates a packet that contains more than 65,536 bytes
 - This packet can cause different kinds of damage to the machine that receives it, such as crashing and rebooting
 - *Process Table*:
 - This attack exploits the feature of some network services to generate a new process each time a new TCP/IP connection is set up
 - The attacker tries to make as many uncompleted connections to the victim as possible in order to force the victim's system to generate an abundance of processes
 - *Smurf Attack*:
 - The victim is flooded with *Internet Control Message Protocol* (ICMP) "echo-reply" packets
 - The attacker sends numerous ICMP "echo-request" packets to the broadcast address of many subnets. These packets contain the victim's address as the source IP address
 - *SSH Process Table*:
 - Like the Process Table attack, this attack makes hundreds of connections to the victim with the *Secure Shell* (SSH) Protocol without completing the login process.



Well-Known DDoS Attacks

- Some of the most famous documented DDoS attacks
 - *Syslogd*:
 - The Syslogd attack crashes the *syslogd* program on a Solaris 2.5 server by sending it a message with an invalid source IP address.
 - *TCP Reset*:
 - As soon as a "tcpconnection" request is found, the malevolent attacker sends a spoofed TCP RESET packet to the victim and obliges it to terminate the TCP connection.
 - *Teardrop*:
 - A Teardrop attack creates a stream of IP fragments with their offset field overloaded.
 - The destination host that tries to reassemble these malformed fragments eventually crashes or reboots.
 - *UDP Storm*:
 - A character generation ("chargen") service generates a series of characters each time it receives a UDP packet, while an echo service echoes any character it receives.
 - The attacker sends a packet with the source spoofed to be that of the victim to another machine
 - Then, the echo service of the former machine echoes the data of that packet back to the victim's machine and the victim's machine, in turn, responds in the same way



Defense Mechanisms

- No fail-safe solution available to counter DDoS attacks
 - The attackers manage to discover other weaknesses of the protocols
 - They exploit the defense mechanisms in order to develop attacks
 - They discover methods to overcome these mechanisms
 - Or they exploit them to generate false alarms and to cause catastrophic consequences.
- There are two approaches to defense
 - *Preventive defense*
 - *Reactive defense*



Defense Mechanisms

- *Preventive defense*
 - try to eliminate the possibility of DDoS attacks altogether
 - enable potential victims to endure the attack without denying services to legitimate clients
 - Hosts should guard against illegitimate traffic from or toward the machine.
 - keeping protocols and software up-to-date
 - regular scanning of the machine to detect any "anomalous" behavior
 - monitoring access to the computer and applications, and installing security patches, firewall systems, virus scanners, and intrusion detection systems automatically
 - sensors to monitor the network traffic and send information to a server in order to determine the "health" of the network



Defense Mechanisms

- *Preventive defense*
 - Securing the computer reduces the possibility of being not only a victim, but also a zombie
 - these measures can never be 100-percent effective, but they certainly decrease the frequency and strength of DDoS attacks
 - Studying the attack methods can lead to recognizing loopholes in protocols
 - adjust network gateways in order to filter input and output traffic
 - reduce traffic with spoofed IP addresses on the network
 - the ----- IP address of output traffic should belong to the subnetwork, whereas the source IP address of input traffic should -----
 - Test the system for possible drawbacks or failures and correct it
 - Two methods have been proposed
 - create policies that increase the privileges of users according to their behavior - when users' identities are verified, then no threat exists. Any illegitimate action from those users can lead to their legal prosecution
 - increasing the effective resources to such a degree that DDoS effects are limited - usually too expensive



Defense Mechanisms

- *Reactive defense a.k.a. Early Warning Systems*
 - try to detect the attack and respond to it immediately
 - they restrict the impact of the attack on the victim
 - there is the danger of characterizing a legitimate connection as an attack
 - The main detection strategies are
 - *signature detection*
 - search for patterns (signatures) in observed network traffic that match known attack signatures from a database
 - easily and reliably detect known attacks, but they cannot recognize new attacks
 - the signature database must always be kept up-to-date in order to retain the reliability of the system
 - *anomaly detection*
 - compare the parameters of the observed network traffic with normal traffic
 - new attacks can be detected
 - in order to prevent a false alarm, the model of "normal traffic" must always be kept updated and the threshold of categorizing an anomaly must be properly adjusted
 - *hybrid systems*
 - combine both these methods
 - update the signature database with attacks detected by anomaly detection
 - an attacker can fool the system by characterizing normal traffic as an attack i.e. an *Intrusion Detection System (IDS)* becomes an attack tool



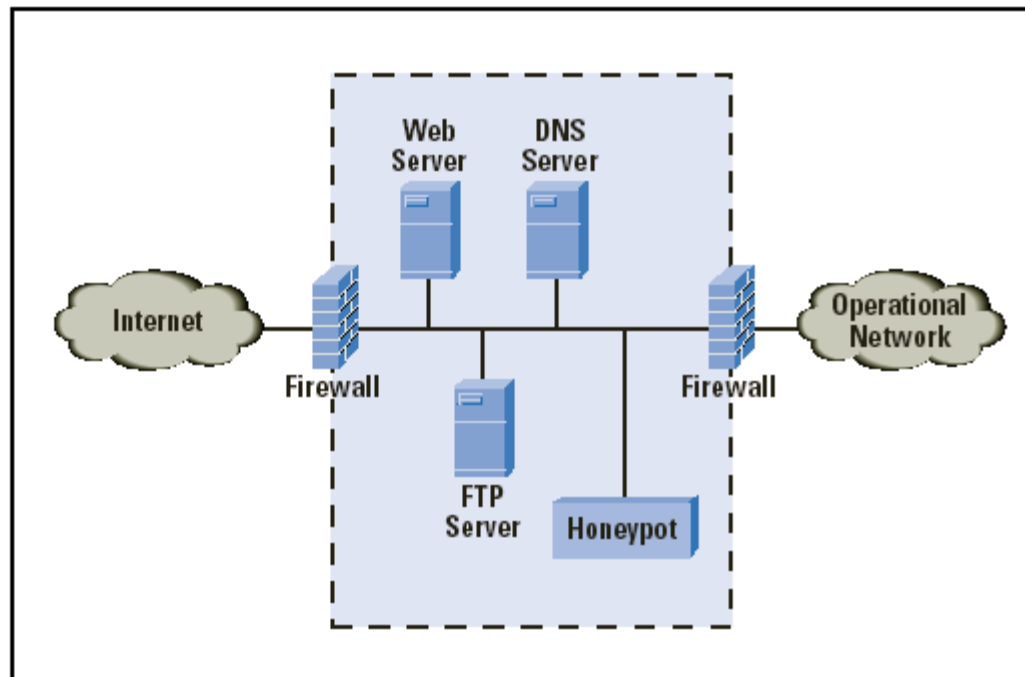
Defense Mechanisms

- Difficulties in defending
 - DDoS attacks flood victims with packets
 - Any attempt of filtering the incoming flow means that legitimate traffic will also be rejected
 - Attack packets usually have spoofed IP addresses which makes it difficult to traceback the source of attacks
 - there is the danger of characterizing a legitimate connection as an attack
- Respond to the attack
 - by limiting the accepted traffic rate
 - legitimate traffic is also blocked
 - Filtering is efficient only if attackers' detection is correct



Modern Techniques in Defending

- Right now there is no 100% effective defense mechanism
- Developers are working on DDoS diversion systems
 - e.g. *Honeypots*



Modern Techniques in Defending

- Honeypots
 - *low-interaction honeypots*
 - emulating services and operating systems
 - easy and safe to implement
 - attackers are not allowed to interact with the basic operating system, but only with specific services
 - what happens if the attack is not directed against the emulated service?
 - *high-interaction honeypots*
 - *honeynet* is proposed
 - *honeynet* is not a software solution that can be installed on a computer but a whole architecture
 - it is a network that is created to be attacked
 - every activity is recorded and attackers are being trapped
 - a *Honeywall* gateway allows incoming traffic, but controls outgoing traffic using intrusion prevention technologies
 - By studying the captured traffic, researchers can discover new methods and tools and they can fully understand attackers' tactics
 - more complex to install and deploy and the risk is increased as attackers interact with real operating systems and not with emulations



Modern Techniques in Defending

- Route Filter Techniques

- when routing protocols were designed, developers did not focus on security, but effective routing mechanisms and routing loop avoidance
- by gaining access to a router, attackers could direct the traffic over bottlenecks, view critical data, and modify them
- cryptographic authentication mitigates these threats
- routing filters are necessary for preventing critical routes and subnetworks from being advertised and suspicious routes from being incorporated in routing tables
- attackers do not know the route toward critical servers and suspicious routes are not used
- Two route filter techniques
 - *blackhole routing*
 - *sinkhole routing*



Modern Techniques in Defending

- Route Filter Techniques
 - *blackhole routing*
 - directs routing traffic to a null interface, where it is finally dropped
 - can ignore traffic originating from IP addresses being attacked
 - CPU time & memory are saved, Only network bandwidth is consumed
 - if the attackers' IP addresses cannot be distinguished and all traffic is blackholed, then legitimate traffic is dropped as well
 - *sinkhole routing*
 - involves routing suspicious traffic to a valid IP address where it can be analyzed
 - traffic that is found to be malicious is rejected (routed to a null interface); otherwise it is routed to the next hop
 - the effectiveness of each mechanism depends on the strength of the attack.
 - Specifically, sinkholing cannot react to a severe attack as effectively as blackholing
 - However, it is a more sophisticated technique, because it is more selective in rejecting traffic
 - filtering seems to be effective technique but the ISP's network is already flooded
 - the best solution would be to filter traffic on the source; in other words, filter zombies' traffic



Modern Techniques in Defending

- Route Filter Techniques
 - *filtering on source address*
 - best technique if we knew each time who the attacker is
 - not always possible to detect each attacker especially with the huge army of zombies
 - *filtering on services*
 - *filter based on UDP port or TCP connection or ICMP messages*
 - *not effective if the attack is directed toward a very common port or service*
 - *filtering on destination address*
 - *reject all traffic toward selected victims*
 - *legitimate traffic is also rejected*



Modern Techniques in Defending

- Hybrid methods and guidelines
 - try to combine the advantages from all the methods stated previously in order to minimize their disadvantages
 - victims must detect that they are under attack as early as possible
 - they must trace back the IP addresses that caused the attack and warn zombies administrators about their actions
- However, this is currently impossible and users must care for their own security
- Some basic guidelines
 - Prevent installation of distributed attack tools on our systems
 - restrict the zombies army
 - keep protocols and operating systems up-to-date
 - prevent system exploitation by eliminating the number of weaknesses of our system
 - Use firewalls in gateways to filter incoming and outgoing traffic
 - block incoming packets with source IP addresses belonging to the subnetwork
 - block outgoing packets with source IP addresses not belonging to the subnetwork
 - Deploy IDS systems to detect patterns of attacks
 - Deploy antivirus programs to scan malicious code in our system
- It appears that both network and individual hosts constitute the problem, consequently, countermeasures should be taken from both sides



Modern Techniques in Defending

- Final Thoughts
 - attackers cooperate to build the perfect attack methods
 - legitimate users and security developers should also cooperate against the threat



Reference

**“Distributed Denial of Service Attacks”,
The Internet Protocol Journal - Volume
7, Number 4**

– *by Charalampos Patrikakis, Michalis
Masikos, and Olga Zouraraki
National Technical University of Athens*



DDoS Attacks

Questions ?

